Stability Assessment

Nexo InOuty backend (API): how stable the server is today, and what fixing the bugs would change

29 October 2026 · companion to *Bug-Report.pdf* (29 bugs, details and effects)

6.5/10
Today

8–8.5/10
After the **11 most important** fixes

9/10
After **all 29** bugs are fixed

Verdict

The server is in good shape where it matters most for a multi-company system: sign-in, sessions and role checks held against every attack tried, and each company's data stays separate everywhere except in one place. **That one place is the High bug**: the face-recognition machine (BUG-501) is shared by every company, so one company can pull another company's punches. The other weak spots are in **attendance and planning**: the kiosk can block a normal morning clock-in, overtime after midnight is lost, and a few actions (copying a month, clearing the machine) lose data without warning. None of these crash the server; they give wrong results quietly.

Score by area

Area	Score	Why
Sign-in, sessions, roles	9	All 84 routes checked against every kind of caller; forged, replayed and stolen tokens refused; accounts lock after repeated failures. Only Low bugs (BUG-101 to 104).
Company separation	7	The database layer refuses to read or change another company's records, and fails closed. The exception is the shared clocking machine (BUG-501, High).
Employees, shifts, tasks	7	Works; a manager can raise their own salary (BUG-203) and a shift still planned is deleted without warning (BUG-204).
Work time, advances, bonuses	6	Pay data is stored as sent, but the server doesn't stop a day saved twice (BUG-403) or a negative advance (BUG-401); the frontend guards both today.
Planning and exports	6	Saving and copying work, but copying a month wipes days it doesn't copy (BUG-304) and the exports drop afternoon and evening shifts (BUG-306).
Attendance, kiosk, machines	4	The High bug, plus a blocked morning clock-in at the kiosk (BUG-504), lost overtime after midnight (BUG-505) and punches skipped after clearing the machine (BUG-502).

What the score is based on

Evidence	Result
Automated tests	923 passing tests in 31 files, run against the real application and a real MongoDB database; **99.8%** of lines and 93.7% of branches covered; same result on 4 runs in a row
Known bugs	**29** bugs, each proven by a test that fails until it is fixed: **1 High**, **10 Medium**, **18 Low**

Evidence	Result
Security checks	Every route called without a login, as a kiosk account, manager, admin, super admin and from a company without the feature; injection, forged tokens, token theft, brute force and plain-HTTP attempts
Continuous checks	A GitHub Actions workflow runs lint, build and all tests with coverage thresholds on every push and pull request to `dev` and `main`

What earns points

- Sign-in, session renewal, theft detection and role checks are solid.
- Company data is separated by the database layer itself, not route by route.
- Clear error messages in English, French and Arabic; bad input is refused, not crashed on.
- The clocking machine's pushes are checked, de-duplicated and stored per company.
- Very high test coverage and CI: a change that breaks something is caught before release.

What costs points

- **One company can reach another's data**: the shared face-recognition machine (BUG-501).
- **Wrong pay in common cases**: overtime after midnight lost, a day saved twice, a negative advance, a manager raising their own salary.
- **Silent data loss**: copying a month, punches skipped after clearing the machine, shifts deleted while planned.
- **Blocked workflow**: the kiosk refuses a normal morning clock-in after a day shift.

How to raise the score

Step	Bugs to fix	Expected score
1. Close the gap between companies	BUG-501: give each company its own machine address, and refuse the machine routes to companies without one	**about 7**
2. Stop wrong pay and data loss	The 10 Medium bugs: BUG-203, 204, 303, 304, 306, 401, 403, 502, 504, 505	**about 8–8.5**
3. Fix the rest	The 18 Low bugs: time zones, messages, rare races, requests the app never sends	**about 9**
4. Confirm in real conditions	Watch the first pushes from the real ZKTeco machine in the server logs, and run a week of real clock-ins through the kiosk	**needed for 9+**

Limits of this assessment

The rating covers the **backend** (the API server); the frontend has its own assessment. The tests run the real application against a real MongoDB database, but the face-recognition machine is simulated and the ZKTeco push format follows the protocol documentation, not captured traffic from the real device. Load, performance and the Render hosting set-up were not tested. Every bug listed has a test, so each fix can be confirmed objectively: when a bug is fixed, its test starts passing.